

SANDIA REPORT

SAND2024-14308

Printed October 2024



Sandia
National
Laboratories

DEReliction: A Cybersecurity Vulnerability Assessment Methodology for Distributed Energy Resources

Jon Hurtado, C. Birk Jones, Jay Johnson & Brian Wright

Prepared by
Sandia National Laboratories
Albuquerque, New Mexico 87185
Livermore, California 94550

Issued by Sandia National Laboratories, operated for the United States Department of Energy by National Technology & Engineering Solutions of Sandia, LLC.

NOTICE: This report was prepared as an account of work sponsored by an agency of the United States Government. Neither the United States Government, nor any agency thereof, nor any of their employees, nor any of their contractors, subcontractors, or their employees, make any warranty, express or implied, or assume any legal liability or responsibility for the accuracy, completeness, or usefulness of any information, apparatus, product, or process disclosed, or represent that its use would not infringe privately owned rights. Reference herein to any specific commercial product, process, or service by trade name, trademark, manufacturer, or otherwise, does not necessarily constitute or imply its endorsement, recommendation, or favoring by the United States Government, any agency thereof, or any of their contractors or subcontractors. The views and opinions expressed herein do not necessarily state or reflect those of the United States Government, any agency thereof, or any of their contractors.

Printed in the United States of America. This report has been reproduced directly from the best available copy.

Available to DOE and DOE contractors from

U.S. Department of Energy
Office of Scientific and Technical Information
P.O. Box 62
Oak Ridge, TN 37831

Telephone: (865) 576-8401
Facsimile: (865) 576-5728
E-Mail: reports@osti.gov
Online ordering: <http://www.osti.gov/scitech>

Available to the public from

U.S. Department of Commerce
National Technical Information Service
5301 Shawnee Road
Alexandria, VA 22312

Telephone: (800) 553-6847
Facsimile: (703) 605-6900
E-Mail: orders@ntis.gov
Online order: <https://classic.ntis.gov/help/order-methods>



ABSTRACT

With the increasing integration of Distributed Energy Resources (DER) into the electric grid, maintaining grid reliability and resilience requires that these devices remain secure. This paper discusses a cybersecurity vulnerability assessment methodology that incorporates best practices from Sandia National Laboratories, SANS Institute, OWASP Foundation, and other web and Internet of Things (IoT) penetration testing (“pen testing”) programs, courses, and frameworks for assessing the security posture of devices. The methodology involves five sequential steps: (1) Collect Public Information, (2) Extract Hardware Details, (3) Inventory Software Components, (4) Identify Vulnerabilities, and (5) Test Vulnerabilities. Each step uncovers potential weaknesses in both hardware and software components of DER devices, considering adversary tactics, techniques, and procedures (TTPs), and potential attack vectors along the way. The results from the execution of this method on multiple residential- and small commercial-scale photovoltaic (PV) inverters revealed hardware and software vulnerabilities, which highlight the benefit of taking a methodical approach to discover vulnerabilities. While the specific vulnerability details are not shared here, a generalized overview of findings underscore the importance of robust security assessments for DER devices. Adoption of an assessment framework of this kind will identify and mitigate cybersecurity threats and bolster the resilience of DER-integrated electric grids.

This page intentionally left blank.

CONTENTS

1. Introduction	9
1.1. Research Problem	9
1.2. Objective	9
1.3. Related Work	10
1.3.1. Applications	11
1.3.2. Assessment Methods	11
2. Assessment Methodology	13
2.1. Step 1: Evaluate Public Information	13
2.1.1. Collection Methods	14
2.1.2. Document Content	14
2.2. Step 2: Extraction of Hardware	15
2.3. Step 3: Inventory Software Components	17
2.4. Step 4: Identify Vulnerabilities	19
2.4.1. Assessment Methods	19
2.4.2. Device Systems	20
2.5. Step 5: Test Vulnerabilities (Proof of Concept)	21
3. Example Outcomes	23
3.1. Public Information	23
3.2. Hardware Access	24
3.3. Software Security Deficiencies	24
4. Discussion	27
5. Conclusion	29
6. Acknowledgments	31
References	33

This page intentionally left blank.

LIST OF FIGURES

Figure 2-1. Block diagram depicts the 5 steps necessary to assess a Distributed Energy Resource (DER) Device.	13
Figure 2-2. This figure depicts the hardware levels of extraction approach for identifying physical access vulnerabilities.	16

This page intentionally left blank.

1. INTRODUCTION

The electric grid faces increasing cybersecurity threats, with adversaries keen on targeting Distributed Energy Resource (DER) devices such as solar Photovoltaic (PV) systems. Exploiting vulnerabilities in these devices can have significant implications for both local and bulk electric power system performance. Furthermore, compromised devices can serve as entry points for adversaries to access other critical infrastructure systems, underscoring the urgency for cybersecurity measures in the DER sector.

1.1. Research Problem

Past publications, public notices, and cyber-attacks stress the importance of securing critical infrastructure assets. Vulnerabilities may exist in the DER device hardware, its software, or the associated Operational Technology (OT) networks [18]. And, security concerns will grow as more digital technologies connect to the power grid and expand the overall attack surface. However, many vendors, especially those new to the market and/or offering limited products, lack processes for vulnerability evaluations. In some cases, companies lack internal expertise. Yet, even with experts on staff, companies may lack a well-defined, repeatable, and comprehensive methodology. Because of the critical role DER devices have on the electric grid, an effective vulnerability assessment methodology provides essential services for maintaining system integrity.

1.2. Objective

Addressing security gaps requires the implementation of a comprehensive Vulnerability Assessment and Penetration Testing (VAPT) methodology for DER devices. A well-defined VAPT builds on the many evaluation tools. These tools include scanners, like Nessus, Burp Suite, Nmap, OpenVAS, and others. Although effective, the implementation of scanners alone and other one-off Penetration Testing (PT) techniques lack a repeatable and well-defined step-by-step process that encompasses a complete review of a devices vulnerabilities.

Often, security evaluations involve one-off scanning and PT tests which results in varied results that depend on the expertise of the assessor. For this reason, this paper outlines pertinent steps that enable effective and repeatable evaluations of DER device vulnerabilities. Using existing insights, the 5-step process begins by mimicking the behavior of an adversary targeting a specific device. Followed by a testing assessment techniques that incorporates well-known resources, such as scanning tools, that take into account adversary behaviors. Various examples where testing procedures account for adversary actions include:

1. Lockheed Martin Killchain provides a model that identifies actions an adversary must perform to successfully penetrate a device [11, 7].
2. MITRE ATT&CK Framework provides a guideline for describing cyber-attacks [25].
3. Sandia National Laboratories' Cooperative Adversary Security Assessment (CASA) Techniques: This is a collection of step-by-step techniques for performing pen testing and red teaming, including Information Design Assurance Red Team (IDART™) for systems analysis during design and development and Field Device Assessment Methodology (FDAM) for networked devices like remote sensors or controllers.
4. SANS Institute Courses & Certificates: Hands-on courses taught by experts designed to help students master techniques and tools useful for evaluating Internet of Things and Enterprise networks and connected devices.
5. Offensive Security PEN-200: Penetration testing course that teaches the tools and techniques offered within the Kali Linux operating system.
6. Open Source Intelligence (OSINT) Framework: Defines an approach for gathering information from sources like news articles, social media, government reports, online forums, and other OSINT resources.
7. Idaho National Laboratory Cyberstrike STORMCLOUD, LIGHTS OUT, and NEMESIS.

With insights from previous work, this approach recognizes the importance of information gathering and begins with OSINT assessments of online documents and other data that require minimal effort, cost, and exposure. With device installation and operations information in hand, the evaluation considers the likely approaches an adversary would take to scrutinize the target device's hardware and software in hopes of finding opportunities to access the physical or digital spaces. Then, with knowledge of the device's attributes and features, the assessment leverages tools an adversary would use to find exploitable interfaces. Finally, to validate the identified weaknesses, an evaluator confirms that the system's predetermined vulnerabilities can be tampered and/or modified by executing PTs. This step may also uncover new previously undiscovered issues.

1.3. Related Work

Past literature includes development and execution of cybersecurity assessment methods. They incorporate vulnerability scanners that identify potential weaknesses [29] or conduct PT [1] to discover issues with fielded systems. In addition to the literature, many companies offer vulnerability assessment services. Their services vary from system scans to reviews of information technology (IT) and OT networks. These companies stress the importance of a strong prevention and mitigation systems. Their methods for identifying vulnerabilities, however, are not well explained - likely because they are proprietary. Published conference and journal papers provide more background on the subject and descriptions of pertinent publications are discussed in the following subsections.

1.3.1. Applications

Industrial control applications, for example, receive significant attention because of its prominence and the potential consequences of a breach. Generally the methods include similarities, but the documented details vary. A typical approach includes the identification of vulnerabilities as a first step followed by a threat modeling effort. A 2019 review paper found that vulnerability methodologies focused on identification and prioritization, while minimal work was done for patch management [23]. One example paper, which focused on supervisory control and data acquisition (SCADA) systems, describes a three level assessment methodology: (1) system, (2) scenarios and (3) access points [27]. These, and other papers, offer useful information for vulnerabilities in SCADA connected devices. However, the past work lacks a comprehensive approach that begins at information gathering, performs both hardware and software evaluations, and concludes with a validation of the discovered issues.

SCADA networks received significant attention in past work. One example describes an approach for reviewing network traffic, system configurations, and other elements associated with the overall system [10]. Additionally, [21] and [6] discuss guidelines for administering evaluations that identify vulnerabilities in infrastructure and not specific devices. In contrast, this paper, focuses on vulnerability assessments of individual DER devices connected and supplying power to the electric grid.

Other research papers focused on smart grid vulnerabilities for the power system as a whole. [16] and [24] stress the need to evaluate and model vulnerabilities within the network in order to understand and potentially quantify the impacts. This approach provides a mechanism for considering risk, but, again, does not examine individual devices in detail, which this work does by including a review of the specific hardware and software components within the DER device.

Other research investigates the impact of cyber-attacks on PV inverters [32], which include vulnerability identification. A similar paper identified and reported a total of 23 vulnerabilities [8]. Other work evaluated the potential risks of malicious actions [28, 14], which highlight the need for protecting large scale systems. However, details regarding specific methods used to assess individual PV inverters and other DER devices are rare and lack specific details or insights.

1.3.2. Assessment Methods

PT methods provide useful evaluations of computer system or network security [3] by attempting to exploit weaknesses in a target system. For example, a VAPT evaluation, consists of both a Vulnerability Assessment (VA) and PT [26]. The VAPT life cycle, described in [9], includes reconnaissance, vulnerability detection, information analysis, PT, privilege escalation, results analysis, reporting, and clean-up. Another example vulnerability methodology provides a four step approach for vulnerability testing but lacks the details and descriptions provided in this paper [30]. PT methods clearly provide useful insights and part of multiple applications. The Open Web Application Security Project (OWASP) organization, for instances, provides an overview of PT methodologies [22]. PT examples and it's ability to ensure the security of critical systems, like

banking [15], exist in the literature. But, PT alone will not provide a comprehensive review of a device's security since it lacks an analysis of hardware and software inventories and functions.

Threat modeling also provides evaluators with an approach for identifying and prioritizing potential threats to a system's security. Threat modeling tools and approaches mimic actions an attacker would use to compromise the security of a device. Some examples include the use of the MITRE ATT&CK resource [20] as seen in [34]. In the end, implementing this type of modeling aids in defining the appropriate security requirements for the specific applications [19]. Similarities between the this paper's vision and threat modeling exist. Yet, structural differences are apparent. This paper provides an overall methodology for implementing adversary informed assessments throughout each step in the evaluation. Threat modeling, on the other hand, does not provide such a structure. Instead, threat modeling focuses on the specific techniques involved in emulating a threat. Therefore, threat modeling tools and techniques can be used within the proposed framework for accessing DER devices.

This paper contributes to the existing body of literature by focusing on the development of a comprehensive vulnerability assessment methodology specifically tailored to DER devices. Other published methodologies tend to have a broad focus that does not include sufficient specifics for executing meaningful tests. Others have tailored methods not applicable to DER devices, like industrial or SCADA network connected devices or website security evaluations.

In summary, past research details various threat modeling approaches, but they do not describe how it fits into a complete vulnerability assessment process. This highlights a unique contribution of this paper, which is to specify how threat implementations contribute to a comprehensive evaluation process.

2. ASSESSMENT METHODOLOGY

The vulnerability assessment methodology involves a systematic approach for analyzing hardware and software components, identifying potential issues, and validating vulnerabilities in a DER device. Figure 2-1 depicts this five step process. The methodology relies on a specific sequence of operations. If steps are skipped, critical information on the system's security posture will be missed. Or executing steps out of order will result in missed opportunities to effectively evaluate systems or components since information from preceding steps inform subsequent evaluations. Basically, the outcomes from each step inform tasks in the proceeding evaluation steps and thus providing a fully informed and robust VA.

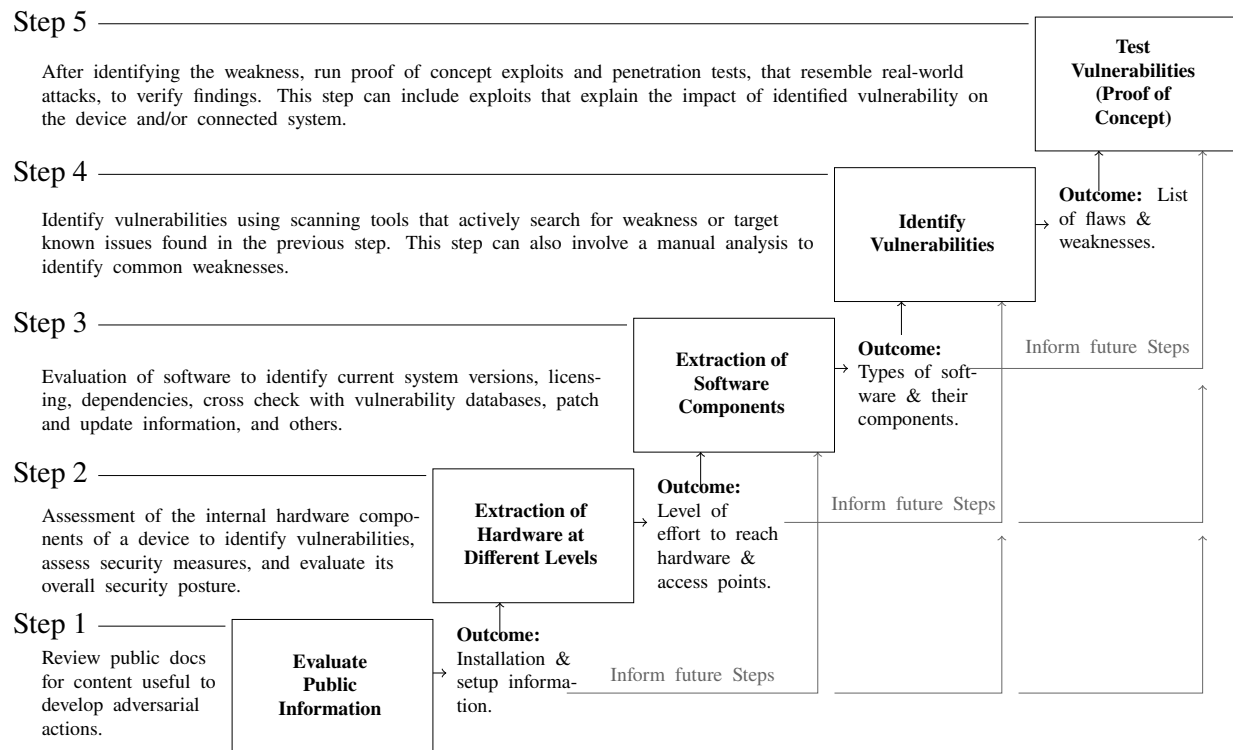
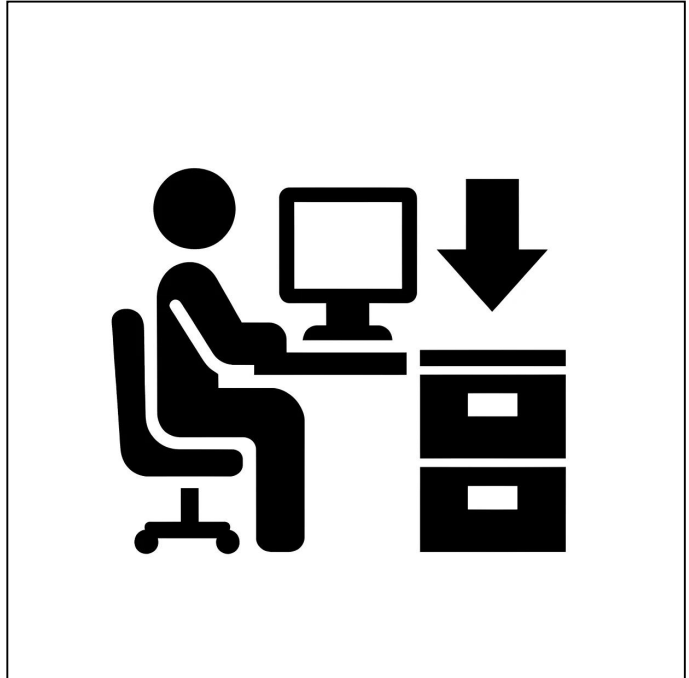


Figure 2-1. Block diagram depicts the 5 steps necessary to assess a Distributed Energy Resource (DER) Device.

2.1. Step 1: Evaluate Public Information

DER vendors commonly share device specifications, which provide useful information for both users as well as potential adversaries. These documents contain background information, equip-

Step 1:
Search, gather, store,
and assess openly
available information
on the target device.



ment specifications, installation requirements, operations methods, credentials for gaining software access to configure the system, and other useful information. Some of this information, although useful for customers, utilities, installers, and operators, can be used maliciously to inform and help adversaries find and abuse device hardware and software systems. Therefore, in-depth security, that limits exposing critical information to adversaries requires the vetting of content and dissemination methods.

2.1.1. *Collection Methods*

To gather information, this methodology utilizes the “OSINT Gathering Techniques” framework. This involves passive data collection to scrape publicly available websites, access open APIs, extract data from forums and company websites or services. The first step generally involves a search to obtain the relevant documents. This can include internet searches, email inquiries and other methods. After that, reviewers perform an analysis of content, extract metadata, and if necessary, contacts with vendor help desks.

2.1.2. *Document Content*

This assessment of content attempts to quantify the sensitivity or potential relevance to security. This could include the identification of configuration settings, default passwords, network interfaces, and communication protocols. This information may be available in user documents that describe hardware, software, and communication components. In many cases, conveyance of this information occurs via two documents and include the following topics:

- Installation Manual Document
 - Technical Specifications
 - System Requirements
 - Mounting Requirements
 - Electrical Installation
 - Startup & Commissioning
 - Operation & Maintenance
- Warranty & Support
- User Manual Document
 - Safety Information
 - Operation Overview
 - Configuration/Settings
 - Trouble Shooting

2.2. Step 2: Extraction of Hardware

Step 2:
Dissect hardware to
discover the level of
effort required to access
an entry point.



A second step involves a detailed evaluation of the device's hardware components from the perspective of an adversary attempting to gain access. When accessing a device, an adversary considers risks associated with the time, materials, and overall safety required to penetrate the hardware. To reduce these risks, an adversary may perform work in stages that include learning, discovery, and finally exploitation. Prior to an attack, an adversary likely evaluates the devices to learn what is available and how to access it. While performing a hardware investigation, the adversary will search for hardware components that could modify the system's performance and provide one or more points of entry into the local device. With this information, the adversary will know how to make unwanted changes.

This method entails actions by the evaluator to systematically breach the device and quantify

the physical access characteristics (as depicted in Figure 2-2). It begins with entry into the device's enclosure and moves all the way through to a point where the adversary could access critical component(s), software, or other essential system components. During this evaluation, the hardware weaknesses (or flaws) refer to the level of effort required to gain unwanted entry and access to critical boards, chip sets, network connections, physical access ports, and other useful hardware elements.

The breakdown of the device includes multiple levels of extraction, as depicted in Figure 2-2. It begins at level 1 by accessing components or systems in the easiest manner possible. At this level, the evaluator removes items without breaking any components or causing any physical changes to the device. After completing this initial level, the next evaluation, at level 2, involves moving and/or removing components by hand without the use of any tools. Then, at level 3, the evaluator can use readily available and non-intrusive tools to access the inter-components of the device. This progression from level to level continues at the discretion of the evaluator. Ultimately, in the final level, the evaluator is using any means necessary to access all parts within the device.

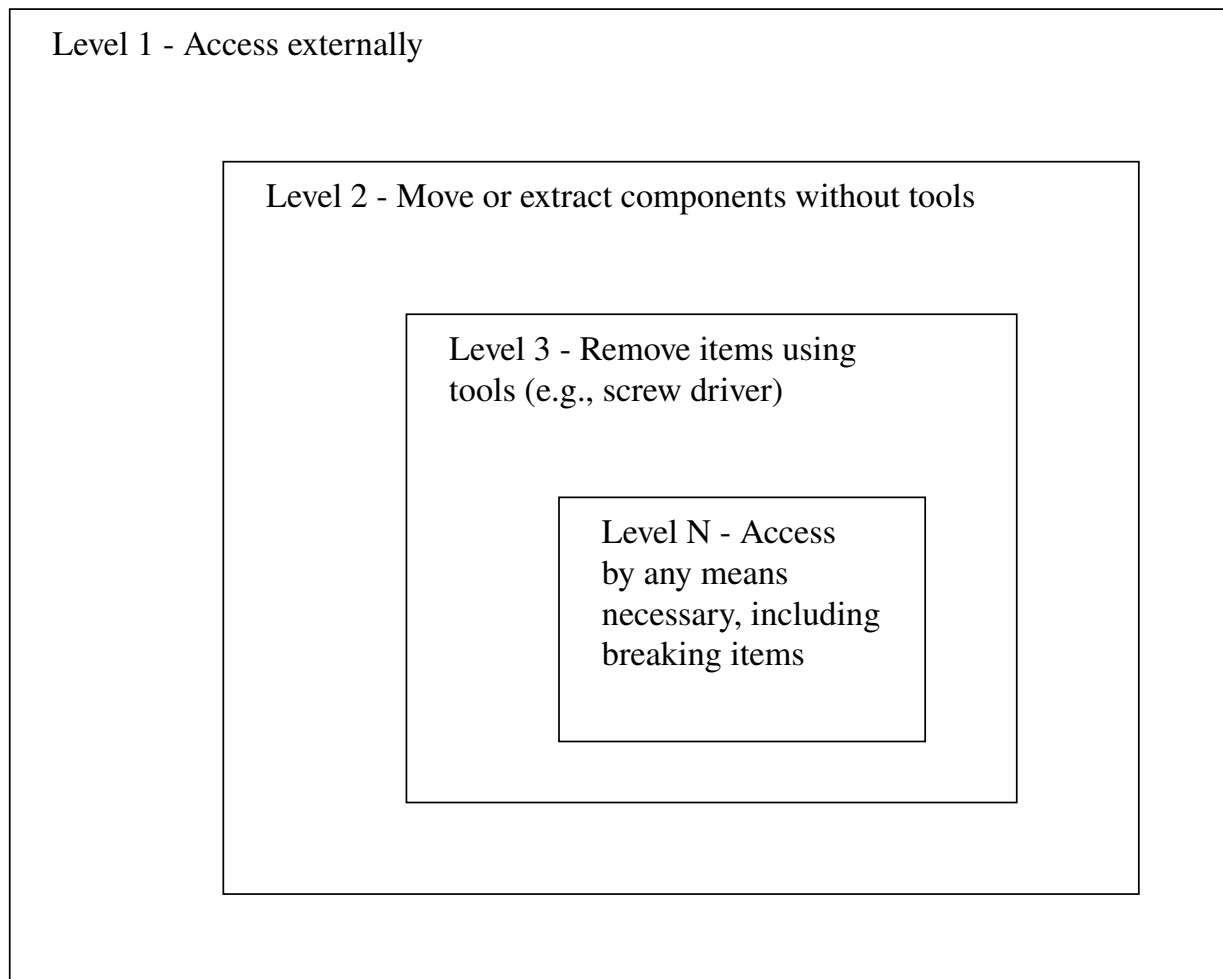


Figure 2-2. This figure depicts the hardware levels of extraction approach for identifying physical access vulnerabilities.

Throughout the different levels, depicted in Figure 2-2, the evaluators are documenting their methods for access, and describing what each level reveals inside the device. Photographs will also provide essential content for tracking and sharing information. Also, these records will assist in future steps and other evaluations of different device manufacturers or types.

This evaluation considers two operating modes, which are de-energized or energized. De-energized refers to the devices state where it is not connected to the live electrical network or turned off. The energized mode provides power to internal electrical components, which could shock a person attempting to breach sections of the device. These steps are established to first identify through a de-energized device what hardware vulnerabilities exist. Sometimes these hardware vulnerabilities are not exploitable on a “live” energized device. Other times these vulnerabilities are exploitable, especially if there are hardware versions that support known capabilities beyond the functional operation of the PV inverter.

In theory, an adversary could have the opportunity to access a device in either mode. De-energizing a PV inverter, for example, involves opening disconnect switches on the alternating current (AC) and direct current (DC) sides of the inverter. This may be applicable in certain installation environments, however in other cases, switches may not be readily available. That being said, any hardware vulnerabilities identified through this breakdown have an opportunity to be exploitable when the system is connected to the grid - since there are mechanisms to shut down or de-energize the system.

2.3. Step 3: Inventory Software Components

Step 3:
Identify the software
components inside the
device.



For PV inverters, turning on a device entails a connection to the electric grid on the AC side and, the DC side requires physical PV modules, a PV simulator, or DC power supply. This important step may only be available in a well-equipped laboratory. Once connected, multiple data collection methods exist. A more standardized approach involves a well-formed Software Bill of Materials (SBOM) where vendors actively participate and share methods of access to computing environments and software. Without vendor support, evaluators will utilize various methods that include, but not limited to the following actions:

1. Physically removing and reading memory media
2. Brute forcing DER passwords to gain access to the operating system
3. Using serial and other interfaces to access the file system
4. Locating firmware/software updates online

Although these methods involve both passive and active hacking methods that leverage vulnerabilities, the primary intent is to not identify security flaws associated with device access, but instead view, review, and determine issues associated with software and firmware elements. Once accessed, a common practice for evaluating software involves a comprehensive inventory of the software components and dependencies. This practice, often referred to as SBOM, provides a mechanism for defining and tracking device software [31]. This gathering of information entails the following items:

1. Name: Title of the software
2. Version: Identifying the release version
3. Vendor: Company that created or distributes the software
4. License Information: Type of license governing the use of the software
5. Dependencies: Software or libraries that the component relies on
6. Installation Location: Directory where the software is installed

Reviews by trained software development and cybersecurity practitioners lead to the identification of potential risks. These experts leverage tools that identify software types and their settings. For instance, [12] reviews a handful of tools useful for scanning dependencies, evaluate Node Package Manager (npm) projects, and other tasks. Other examples in literature include java-based software vulnerability assessments [33] as well as open-source tools [4] that provide a complete overview of system software, their features, and their settings. From this thorough review, evaluators will identify security weaknesses, exploitable configurations, and potential errors in the software's code base that allows for adversaries to complete an unwanted modification.

2.4. Step 4: Identify Vulnerabilities

The *Identify Vulnerabilities* step discovers weaknesses and flaws in the device that would result in unwanted access and modification. As the evaluator conducts the assessment at the stage, threat modeling tools and other resources achieve the following objectives: (1) confirm previously discovered issues are vulnerabilities and (2) identify new security flaws in the device.

Step 4:
With information from
previous steps, identify
potential weakness
and flaws.



2.4.1. Assessment Methods

The vulnerability assessment executes a series of tests that leverage existing tools. Some open-source tools provide sufficient resources for conducting evaluations [2, 13] and include the following actions:

1. **Execute Scans:** Perform examinations of systems, networks, applications, and other environments. For example, port scanners begin by picking a target. Then, to administer an evaluation of a TCP connection, the evaluator attempts to establish a complete TCP connection with ports of interest. In this case, the scan entails sending and receiving network packets.
2. **Perform Configuration Assessments:** Review software directories and files to assess configurations, settings, and permissions, identifying systems susceptible to tampering and/or corruption. If helpful, the Center for Internet Security (CIS) security benchmarks can be used which involve: (1) establishing a baseline, (2) monitoring configuration changes, (3) identifying configuration risks, and (4) identifying remediation measures.

3. **Confirm Patch Status:** Evaluate the status of installed patches and updates to identify outdated versions and missing patches. This step involves the collection of information on the latest available software patches. This can be executed manually or, missing patches can be identifying automatically using tools like Windows Server Update Service (WSUS), Ivanti, Manage Engine Patch Manager, or Qualys. Other manual tasks include reviews of update history, comparison of installed versions with the most recent version, and others. Another manual evaluation involves cross-referencing observations with known vulnerabilities listed in the National Vulnerability Database (NVD) or other resources provided by government or private entities.
4. **Perform Compliance Checks:** Apply solutions that evaluate systems to define how the computing environment compares with specific standards. Example tools, useful for executing this comparison, include Tenable, Tripwire, and Rapid7 Nexpose. For PV, the tools should be tuned to check whether it complies with IEC 62443 (cybersecurity of Industrial Automation and Control) and NIST SP 800-82 (Guideline for Industrial Control System Security.) The evaluation can include a review of the devices communication components. For PV inverters, this requires checks to see that standardized IEEE 2030.5, SunSpec Modbus, or DNP3 protocol software stacks are correctly configured.

2.4.2. *Device Systems*

The evaluation at this stage provides an all-encompassing review that includes, but not limited to the following areas:

1. **Network Capabilities:** A device's connection with external sources may include weaknesses associated with open or improperly managed ports and services, insecure communication methods and protocols. Common protocols for DER devices include Modbus, DNP3, and IEEE 2030.5, which if not implemented properly will result in the passage of plain text data that can be read and manipulated.
2. **Software:** Adversary exploits can take advantage of software code errors, insecure libraries, configuration issues, etc. These software issues could result in buffer overflows/underflows, client-side input/injection, and others.
3. **Web Application:** The interface between the device and a human can also be exploited. Improperly structuring the database could lead to unauthorized access via an SQL injection. Websites may not be equipped to handle cross-site scripting (XSS), or other attacks like CSRF which would result in potential compromise if certain conditions were met.
4. **Authentication:** Weaknesses in the management of users can include improper session management, password management, key management, and others. This type of vulnerability could lead to privilege escalation, where an adversary gains unauthorized access to higher rights in the system. Some systems do not have privilege separation in place, which by default makes every user a super user or administrator of the device.

5. Hardware: Adversary's may also leverage physical security weaknesses to gain unauthorized access through hardware components. This type of access has been shown to have results that not only impact the devices but as well to the businesses that support these devices for their customer base.

2.5. Step 5: Test Vulnerabilities (Proof of Concept)

Step 5:
Execute threats that
exploit the known and
unknown vulnerabilities.



Each vulnerability identified in the previous steps undergo a secondary review to prove that the issue truly exists and can be exploited. This stage in the evaluation, commonly referred to as a proof of concept (PoC) uses PT techniques that include the following steps:

1. Identify Target: Select the target system, application, or network component where the vulnerability is suspected to exist. Gather information about the suspected vulnerability, including its description, potential impact, and any known exploits or attack techniques required for exploitation.
2. Reproduce Environment: Set up an environment that closely resembles the target system or native installation environment, including the same software versions, configurations, and network settings.
3. Develop & Deploy Exploit: Create or adapt an exploit (code or technique) designed to make use of the identified vulnerability. This could involve writing custom scripts, using existing exploit frameworks, or modifying publicly available proof-of-concept code. Then, run the exploit against the target system or application to verify that the vulnerability can be successfully exploited. Document the steps taken and any observed behavior.

4. **Observe Impact:** Monitor the target system or application for any signs of successful exploitation, such as unauthorized access, data leakage, system crashes, or unexpected behavior.
5. **Document:** Record information about the vulnerability, including the steps taken to reproduce it, the observed impact, and any mitigating factors or conditions. Compile the findings into a PoC report or demonstration that clearly illustrates the existence and impact of the vulnerability. The report shall include screenshots, logs, and other evidence to support the findings.
6. **Review:** Check that the validity of the PoC results by having an external security profession or expert review the report.

3. EXAMPLE OUTCOMES

Implementation of these steps on a small set of PV inverter vendor products identified various issues. This section provides a broad overview of findings. It does not provide details that could aid an adversary beyond what can be found in open-sources resources online, nor will the results implicate a particular vendor.

3.1. Public Information

Sifting through publicly available documents revealed information pertaining to how the devices connect to the internet and what methods could be used to access the software. The main source for information included manuals available through Internet searches and online videos provided by the vendors. Although useful for asset owners and installers, the public information provides sensitive information about a product's external and internal components. It also reveals how access can be achieved.

Online Manual Documents and Video Guides:

- Access to Hardware
 - Identification of the location and means to access communication devices/ports.
 - Explanation concerning the location for the electrical connections.
 - Method for opening enclosures.
 - Method for discovering and accessing ports.
 - Method for identifying and making electrical connections.
- Access to Software
 - Direct declaration of username/password: The documents include a complete description of the default credentials required to access the system's web interface.
 - Indirect declaration of username/password: Documents define how username and passwords can be derived using device specific information such as it's serial number.
 - Method for confirming internet connectivity.
 - Method for accessing and understanding monitoring/control application.

3.2. Hardware Access

The physical examination revealed the complexity involved in accessing internal components such as circuit boards, connectors, chips and other elements by removing the casing. The example implementation, which evaluated PV inverters, uncovered exploitable flaws in hardware components and designs. Through physical access to the device and with appropriate tools and techniques, adversaries could execute malicious activity that includes side-channel attack, fault injection or invasive probing, exploiting unintended information leakage from the physical system.

However, among the PV inverters reviewed, accessing critical components typically demanded substantial effort. This difficulty likely stems from the intent to ensure human safety from hazardous electrical connections, comprising of AC and DC buses, switch gear, and power electronics components. Nonetheless, in certain instances, the communications connections lacked adequate physical barriers to dissuade a determined adversary.

Unfortunately, the communication system for a sample inverter included minimal barriers. Access to this component required no tools or physical force to remove the outer cover. While this accessibility facilitates easy access for installers and commissioning personnel during device setup or maintenance, it also presents an opportunity for adversaries. When following the “levels of extraction” steps access to a critical communication component occurred at level 1. This means that anyone could approach the inverter, access the communication component, or remove it from the inverter without risking injury or electrical shock. Not only are the communication ports directly accessible, but adversaries could also extract the flash drive. As a result, the communications system could easily be shut off, and through direct access to the computing system an adversary could compromise and modify communication and control functionalities.

3.3. Software Security Deficiencies

When applied to the test PV inverters, this assessment identified numerous software security deficiencies. These deficiencies could likely be exploited by an attacker to compromise the confidentiality, integrity, or availability of the system, its data, and other resources. The following observations were made when executing this paper’s step-by-step process:

Input Validation and Sanitation:

Computing resources within PV inverters had inadequate validation or sanitation of user-supplied inputs. Tests found that someone with access to the on-board computer could perform a direct traversal attack and access directories and files outside of the intended limits. Another result of having inadequate validation of user supplied inputs was Local File Inclusion (LFI) with read/write capabilities, and Remote Code Execution (RCE). LFI means that the web application allows an attacker to include files located on the server into the output of the web page. RCE, also presents risks by providing an opening for unwanted code to be executed on the target system. Both the LFI and RCE result from inadequate controls on the web-based Human Machine Interface (HMI), and could lead to data breaches, and even compromise of the PV system.

Authentication and Authorization:

Tests also found weakness associated with mechanisms that manage authentication and authorization. As noted earlier when discussing openly available documentation, weak default passwords left unchanged after commissioning could grant adversaries easy access to systems. In addition to unchanged default passwords, tests found evidence that secure shell (SSH) host and Amazon Web Service (AWS) keys had been left vulnerable. Another examination found a vulnerable web page that required no authentication - allowing a user to see and make changes to the PV system's state.

This page intentionally left blank.

4. DISCUSSION

Through systematic reviews of available documents, hardware, and software components, the approach identified and validated vulnerabilities in PV inverters. Even though the study used a limited sample of PV inverters (10) and vendors (6) and likely did not capture all possible vulnerabilities, it provided useful information for future studies and describes a need for such tests. This approach and results will likely inform existing and future assessments.

One notable research endeavour, “Cyber Testing for Resilient Industrial Control Systems” (CyTRICS) [17], was developed by the Department of Energy (DOE) to offer a standardized, repeatable methodology for prioritizing, testing, and reporting vulnerabilities specific to operational technology (OT). CyTRICS accepts multiple OT devices, including DER equipment. The approach described here could be included in the CyTRICS approach and provide an adaptable means for evaluations that leverages findings from previous tasks or known roadblocks.

Other vulnerability testing examples exist, including new efforts to standardize these tests. A PV inverter testing certification, known as the “SunSpec DER Device Certification”, provides a guideline for certifying the security of a device [5] which must have the following attributes:

1. All listed software components and functions are capable of regular remote and secure updates.
2. There is administration of secure communication protocols without downgrades.
3. User access shall be separable, secure, and have 2-factor authentication.
4. Devices shall have minimal interfaces, and support factory reset functions.
5. The devices shall support collection and transmission of security related logs.

A similar effort is underway to produce, UL 2941 “Standard for Cybersecurity of Distributed Energy and Inverter-Based Resources,” that includes many requirements to improve the security of DER devices.

This page intentionally left blank.

5. CONCLUSION

The vulnerability assessment approach presented in this paper provides a systematic framework for evaluating the cybersecurity posture of DER devices, with a focus on Photovoltaic (PV) inverters. Because of the prevalence of DER devices and their interaction with the electric grid, vulnerabilities in these products represent a significant risk.

This work includes an overview of a 5-step methodology that builds off of past work by incorporating existing tools and frameworks. After applying the approach to PV inverters, the team identified specific and potentially damaging vulnerabilities.

Moving forward, it is imperative for stakeholders, including DER vendors, utilities, regulators, and policymakers, to embrace the integration of cybersecurity assessments into their standard practices. By proactively identifying and addressing vulnerabilities, stakeholders can enhance the security posture of DER devices, mitigate the risk of cyber-attacks, and ensure the continued reliability of the electric grid.

This page intentionally left blank.

6. ACKNOWLEDGMENTS

This article has been authored by an employee of National Technology & Engineering Solutions of Sandia, LLC under Contract No. DE-NA0003525 with the U.S. DOE. The employee owns all right, title and interest in and to the article and is solely responsible for its contents. The U.S. Government retains and the publisher, by accepting the article for publication, acknowledges that the U.S. Government retains a non-exclusive, paid-up, irrevocable, world-wide license to publish or reproduce the published form of this article or allow others to do so, for U.S. Government purposes. The DOE will provide public access to these results of federally sponsored research in accordance with the DOE Public Access Plan.

This material is based upon work supported by the U.S. Department of Energy's Office of Energy Efficiency and Renewable Energy (EERE) under the Solar Energy Technology Office (SETO), Award Number DE-EE00038450.

This page intentionally left blank.

REFERENCES

- [1] Ahmad Almaarif and Muharman Lubis. Vulnerability Assessment and Penetration Testing (VAPT) Framework: Case Study of Governmentâ€™s Website. *International Journal on Advanced Science, Engineering and Information Technology*, 10(5):1874–1880, October 2020. Number: 5.
- [2] Richard Amankwah, Jinfu Chen, Patrick Kwaku Kudjo, and Dave Towey. An empirical comparison of commercial and open-source web vulnerability scanners. *Software: Practice and Experience*, 50(9):1842–1857, 2020. _eprint: <https://onlinelibrary.wiley.com/doi/pdf/10.1002/spe.2870>.
- [3] Matt Bishop. About Penetration Testing. *IEEE Security & Privacy*, 5(6):84–87, November 2007. Conference Name: IEEE Security & Privacy.
- [4] Laura Bottner, Artur Hermann, Jeremias Eppler, Thomas Thüm, and Frank Kargl. Evaluation of Free and Open Source Tools for Automated Software Composition Analysis. In *Proceedings of the 7th ACM Computer Science in Cars Symposium, CSCS '23*, pages 1–11, New York, NY, USA, December 2023. Association for Computing Machinery.
- [5] Businesswire. Intertek test laboratory for sunspec cybersecurity program, 2023.
- [6] Kyle Coffey, Leandros A. Maglaras, Richard Smith, Helge Janicke, Mohamed Amine Ferrag, Abdelouahid Derhab, Mithun Mukherjee, Stylianos Rallis, and Awais Yousaf. Vulnerability Assessment of Cyber Security for SCADA Systems. In Simon Parkinson, Andrew Crampton, and Richard Hill, editors, *Guide to Vulnerability Analysis for Computer Networks and Systems: An Artificial Intelligence Approach*, Computer Communications and Networks, pages 59–80. Springer International Publishing, Cham, 2018.
- [7] Tooska Dargahi, Ali Dehghantanha, Pooneh Nikkhah Bahrami, Mauro Conti, Giuseppe Bianchi, and Loris Benedetto. A Cyber-Kill-Chain based taxonomy of crypto-ransomware features. *Journal of Computer Virology and Hacking Techniques*, 15(4):277–305, December 2019.
- [8] Yatish Dubasi, Ammar Khan, Qinghua Li, and Alan Mantooth. Security Vulnerability and Mitigation in Photovoltaic Systems. In *2021 IEEE 12th International Symposium on Power Electronics for Distributed Generation Systems (PEDG)*, pages 1–7, June 2021.
- [9] Jai Narayan Goel and B. M. Mehtre. Vulnerability Assessment & Penetration Testing as a Cyber Defence Technology. *Procedia Computer Science*, 57:710–715, January 2015.
- [10] Adam Hahn and Manimaran Govindarasu. An evaluation of cybersecurity assessment tools on a SCADA environment. In *2011 IEEE Power and Energy Society General Meeting*, pages 1–6, July 2011.

- [11] Eric Hutchins, Michael Cloppert, and Rohan Amin. Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains. Technical report, Lockheed Martin, 2011.
- [12] Nasif Imtiaz, Seaver Thorn, and Laurie Williams. A comparative study of vulnerability reporting by software composition analysis tools. In *Proceedings of the 15th ACM / IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM)*, ESEM '21, pages 1–11, New York, NY, USA, October 2021. Association for Computing Machinery.
- [13] Omar Javed and Salman Toor. Understanding the Quality of Container Security Vulnerability Detection Tools, January 2021. arXiv:2101.03844 [cs].
- [14] C. Birk Jones, Matthew Lave, Matthew J. Reno, Rachid Darbali-Zamora, Adam Summers, and Shamina Hossain-McKenzie. Volt-Var Curve Reactive Power Control Requirements and Risks for Feeders with Distributed Roof-Top Photovoltaic Systems. *Energies*, 13(17):4303, January 2020.
- [15] Deina Kellezi, Christian Boegelund, and Weizhi Meng. Towards Secure Open Banking Architecture: An Evaluation with OWASP. In Joseph K. Liu and Xinyi Huang, editors, *Network and System Security*, pages 185–198, Cham, 2019. Springer International Publishing.
- [16] Yakup Koç, Martijn Warnier, Robert Kooij, and Frances Brazier. Structural vulnerability assessment of electric power grids. In *Proceedings of the 11th IEEE International Conference on Networking, Sensing and Control*, pages 386–391, April 2014.
- [17] Idaho National Laboratory. CyTRICS: Cyber Testing for Resilient Industrial Control Systems, 2024.
- [18] Zhiyi Li, Mohammad Shahidehpour, and Farrokh Aminifar. Cybersecurity in Distributed Power Systems. *Proceedings of the IEEE*, 105(7):1367–1388, July 2017.
- [19] Stefan Marksteiner, Heribert Vallant, and Kai Nahrgang. Cyber security requirements engineering for low-voltage distribution smart grid architectures using threat modeling. *Journal of Information Security and Applications*, 49:102389, December 2019.
- [20] Mitre. Mitre att&ck®, 2024.
- [21] Nikolaos Nikolaou, Andreas Papadakis, Konstantinos Psychogyios, and Theodore Zahariadis. Vulnerability Identification and Assessment for Critical Infrastructures in the Energy Sector. *Electronicsweek*, 12(14):3185, January 2023.
- [22] OWASP. WSTG - Latest | OWASP Foundation, 2024.
- [23] Qais Saif Qassim, Norziana Jamil, Maslina Daud, Ahmed Patel, and Norhamadi Ja’affar. A review of security assessment methodologies in industrial control systems. *Information & Computer Security*, 27(1):47–61, January 2019.
- [24] Muhammad Rashed, Joarder Kamruzzaman, Iqbal Gondal, and Syed Islam. Vulnerability Assessment framework for a Smart Grid. In *2022 4th Global Power, Energy and Communication Conference (GPECOM)*, pages 449–454, June 2022.

- [25] Shanto Roy, Emmanouil Panaousis, Cameron Noakes, Aron Laszka, Sakshyam Panda, and George Loukas. SoK: The MITRE ATT&CK Framework in Research and Practice, April 2023. arXiv:2304.07411 [cs].
- [26] Sugandh Shah and B. M. Mehtre. An overview of vulnerability assessment and penetration testing techniques. *Journal of Computer Virology and Hacking Techniques*, 11(1):27–49, February 2015.
- [27] Chee-Wooi Ten, Chen-Ching Liu, and Govindarasu Manimaran. Vulnerability Assessment of Cybersecurity for SCADA Systems. *IEEE Transactions on Power Systems*, 23(4):1836–1846, November 2008.
- [28] Armin Teymouri, Ali Mehrizi-Sani, and Chen-Ching Liu. Cyber Security Risk Assessment of Solar PV Units with Reactive Power Capability. In *IECON 2018 - 44th Annual Conference of the IEEE Industrial Electronics Society*, pages 2872–2877, October 2018.
- [29] Sachin Umrao, Mandeep Kaur, and Govind Kumar Gupta. Vulnerability assessment and penetration testing. *International Journal of Computer Communication Technology*, 3:71–74, 2012.
- [30] Robert Vibhandik and Arijit Kumar Bose. Vulnerability assessment of web applications - a testing approach. In *2015 Forth International Conference on e-Technologies and Networks for Development (ICeND)*, pages 1–6, September 2015.
- [31] Boming Xia, Tingting Bi, Zhenchang Xing, Qinghua Lu, and Liming Zhu. An Empirical Study on Software Bill of Materials: Where We Stand and the Road Ahead. In *2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE)*, pages 2630–2642, May 2023.
- [32] Jin Ye, Annarita Giani, Ahmed Elasser, Sudip K. Mazumder, Chris Farnell, Homer Alan Mantooth, Taesic Kim, Jianzhe Liu, Bo Chen, Gab-Su Seo, Wenzhan Song, Mateo D. Roig Greidanus, Subham Sahoo, Frede Blaabjerg, Jinan Zhang, Lulu Guo, Bohyun Ahn, Mohammad B. Shadmand, Nanditha R. Gajanur, and Mohammad Ali Abbaszada. A Review of Cyber–Physical Security for Photovoltaic Systems. *IEEE Journal of Emerging and Selected Topics in Power Electronics*, 10(4):4879–4901, August 2022.
- [33] Lida Zhao, Sen Chen, Zhengzi Xu, Chengwei Liu, Lyuye Zhang, Jiahui Wu, Jun Sun, and Yang Liu. Software Composition Analysis for Vulnerability Detection: An Empirical Study on Java Projects. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering, ESEC/FSE 2023*, pages 960–972, New York, NY, USA, November 2023. Association for Computing Machinery.
- [34] Ioannis Zografopoulos, Juan Ospina, Xiaorui Liu, and Charalambos Konstantinou. Cyber-Physical Energy Systems Security: Threat Modeling, Risk Assessment, Resources, Metrics, and Case Studies. *IEEE access : practical innovations, open solutions*, 9:29775–29818, 2021.

DISTRIBUTION

Email—Internal

Name	Org.	Sandia Email Address
Charles Hanley	8810	cjhanle@sandia.gov
Summer Ferreira	8812	srferre@sandia.gov
C. Birk Jones	8812	cbjones@sandia.gov
Jon Hurtado	9366	jghurta@sandia.gov
Technical Library	1911	sanddocs@sandia.gov

Email—External

Name	Company Email Address	Company Name
Marissa Morales-Rodriguez	marissa.morales- rodriguez@ee.doe.gov	U.S. DOE

This page intentionally left blank.



Sandia
National
Laboratories

Sandia National Laboratories
is a multimission laboratory
managed and operated by
National Technology &
Engineering Solutions of
Sandia LLC, a wholly owned
subsidiary of Honeywell
International Inc., for the U.S.
Department of Energy's
National Nuclear Security
Administration under contract
DE-NA0003525.